

SEE ALSO Newsletter of October 22, 2024
[doc. web n. 10053224]
Provision of July 17, 2024
Register of Provisions
n. 472 of July 17, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN the meeting held today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, members, and
Counsel Fabio Mattei, Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016 (hereinafter, "Regulation");

HAVING REGARD TO the Code regarding the protection of personal data, containing provisions for
the adaptation of the national legal system to Regulation (EU) 2016/679 (Legislative Decree of June
30, 2003, n. 196, as amended by Legislative Decree of August 10, 2018, n. 101, hereinafter "Code");

HAVING REGARD TO the complaint filed by Mr. XX pursuant to
Article 77 of the Regulation, in which he complained of the unlawful processing of personal data by
Seletra S.p.A.;

HAVING EXAMINED the documentation on file;

HAVING REGARD TO the observations made by the Secretary General pursuant to Article 15 of the
Guarantor's Regulation n. 1/2000;

REPORTING Dr. Agostino Ghiglia;

PREMISE

1. The complaint submitted to the Authority and the initiation of the investigation.

With the complaint submitted on 12/28/2021, Mr. XX complained of a violation of the rules regarding
the protection of personal data enacted by Selectra S.p.A. (hereinafter "the Company"), with which he
had a collaboration relationship as a sales agent.

In particular, the complainant stated that, following the termination of the collaboration relationship on
02/24/2021, the Company had kept active the individualized corporate email account assigned to him
during the collaboration relationship ("XX"), accessing the content of all correspondence passing
through the aforementioned account, which, in fact, was produced during a trial initiated before the
Court of Venice.

By note dated 03/14/2022, the Office made a request for information to the Company, pursuant to
Article 157 of the Code, in order to acquire useful elements of evaluation regarding what was stated in
the complaint.

The Company responded with a note dated 04/13/2022 and, on that occasion, specified that:

- "Selectra has never accessed the [email] account used by the complainant during the duration of the
employment relationship";
- "Selectra periodically performs a backup of corporate email accounts using MailStore software. The
execution of the aforementioned backup does not require any access by company personnel, as it is
performed automatically by the MailStore software. The backup of each corporate email account is
kept for a maximum period of three years after the termination of any employment or collaboration
relationship";
- "it has initiated legal action against the current complainant and other parties, [...], following
well-founded suspicions of misappropriation of trade secrets and other illegal acts committed by the
[complainant]";
- "in order to protect its trade secrets, Selectra has mandated the forensic engineering firm XX [...] to

carry out an expert assessment with the aim, among other things, of ascertaining any phenomena of exfiltration of secret corporate data by the [complainant], during the period of validity of the employment relationship”;

- “within this mandate, the firm XX obtained a forensic copy of the backup of the corporate email account [assigned to the complainant], directly from the MailStore application”;
- “the corporate email account [assigned to the complainant] was deactivated within three days following March 5, 2021, the date on which Selectra sent a specific directive to the IT department”;
- “the current status of the account is [...] inactive”;
- “Selectra provided the [complainant] with a copy of the Privacy notice and the company regulations on March 15, 2019”;

A copy of the “Information for external collaborators/representatives, including for sensitive/special data pursuant to Article 13 of EU Regulation 679/2016” was produced in the records, as well as the document concerning “Equipment used by the worker to perform the work and the tools for recording access and attendance”, both delivered to the complainant and signed by him on 03/15/2019.

In particular, the document “Equipment used by the worker to perform the work and the tools for recording access and attendance” specified that:

- “in the event of termination of the employment activity or absence, [the Company reserves the right to] access the mailbox used during the employment relationship, to ensure continuity of work (...)”;
- “the IT system records its accesses to the email accounts and the management system, constantly processing log reports that are kept by the system for a period of at least 6 months”;
- “For the purposes of confidentiality protection, the undersigned informs pursuant to Article 13 of EU Reg. 679/2016 and Article 4 of Law 300/1970 (Workers' Statute) that the tools consistent with the principles of necessity and proportionality as outlined in the Regulation”;
- “the data processing carried out by Selectra [was] conducted in compliance with the principles of relevance and data minimization. The legal basis for the processing is derived from Selectra's right to protect its rights in the face of a well-founded suspicion of massive data theft (including trade secrets and databases) [...]”;
- the Company “promptly deactivated the claimant's email account, without ever accessing it directly, and preserved the data, allowing examination by an external consulting firm, precisely within the limits of the information provided to the claimant, in the manner [...] indicated in the company regulations.”

2. The initiation of the procedure for the adoption of corrective measures by the Authority.

Based on the statements made and the documentation produced during the investigation, the Office proceeded to notify the Company of the initiation of the sanctioning procedure, pursuant to Article 166, paragraph 5, of the Code for the violation of Articles 5, paragraph 1, letters a), c) and e), 13, and 88 of the Regulation, Article 114 of the Code (note of 07/09/2022).

With the defensive memoranda sent on 05/10/2022, pursuant to Article 18 of Law No. 689/1981 and Article 166, paragraph 6 of the Code, the Company represented that:

- “Mr. XX has never been an employee of Selectra, nor has Selectra ever been his employer, as there has only been an agency contract between the parties pursuant to Articles 1742 et seq. of the Civil Code”;
- therefore, “the entire accusatory framework of the alleged violation of the Code is irrelevant (...) as it is based by this Authority on the allegation against Selectra of having carried out a processing of personal data in violation of Article 114 of the Code (which refers to Article 4 of Law 300/1970 as a condition for the lawfulness of processing) (...)”;
- “It should also be noted that the commercial agent was equally external to Selectra's corporate structure in Bolzano or elsewhere; among other things, he did not even have his own office or personal computer (...), operating only outside and at his own independent business (...). It should also be clarified that the commercial agent used the email account that Selectra made available to him exclusively for strictly business-professional use (...) for uses that were entirely personal and unrelated

to his activity as a commercial agent. He then complained if Selectra, after discovering activities of unfair competition pursuant to Article 2589, No. 3 of the Civil Code and the theft of secret data (...), lamented the emergence of his personal emails that he had illegitimately routed through Selectra's email account (...);

- "Selectra has an interest in clarifying that all processing carried out even against its own employees (although the claimant was never one, being an external commercial agent) has been inspired by principles of fairness as indicated in the Regulation."

Regarding the specific aspects of illegality contested, the Company observed that:

- the backup of email accounts, carried out using the Mail Store application, "is a technical security measure" implemented in compliance with Article 5, paragraph 1, letter f) of the Regulation "to ensure the security and integrity of personal data processed against cyber attacks (...). The execution of the backup does not require any access by company personnel, while the maximum retention period of three years is a theoretical parameter that limits the maximum retention time and, consequently, the maximum time for which it is possible to recover data and/or information retrospectively in the event of service disruption or cyber attack";

- regarding the information provided to its employees and collaborators, this "specified the possibility for Selectra to access the content of email accounts for any proven needs of business continuity (...). The purpose indicated in the information provided to the [claimant] is entirely legitimate, as it refers to company email accounts assigned to individuals other than employees. Selectra's commercial agents, in fact, do not have access to the company's management software (CRM, ERP, etc.) and manage their routine exclusively via email";

- "the need to ensure business continuity constitutes the purpose for which Selectra, exclusively through an appointed individual, could access the email account";

- "it must be reiterated that Selectra has never accessed the company email accounts (...). The access carried out by Studio XX, exclusively through the Mail Store application, was conducted on data collected by Selectra for a specific and legitimate purpose of protection in judicial matters pursuant to Article 5, paragraph 1, letter b) and was processed in a manner consistent with the principles of necessity and proportionality as outlined in the Regulation."

legitimate, correct, and transparent pursuant to Article 5, paragraph 1, letter a), since the information provided to the complainant was clear on this point";

- "pending the resolution of the complaint, Selectra has nonetheless decided to suspend the use of Mail Store and to undertake a review process of its privacy notices with the aim of making them even more concise for the data subjects."

3. The outcome of the investigation and the procedure for the adoption of corrective measures.

As a result of the examination of the statements made by the party during the proceedings, as well as the documentation acquired, it appears that the Company, as the data controller, has carried out certain processing operations that are not compliant with the regulations on personal data protection. In this regard, it is highlighted that, unless the act constitutes a more serious offense, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or the exercise of the powers of the Guarantor."

In particular, it has emerged that the Company commissioned a forensic engineering firm to conduct an investigation into the content of the complainant's email using the Mail Store application (installed on company PCs). The emails collected through the application (identified by the complainant as 34) were used in a judicial proceeding initiated against the complainant before the Court of Venice.

It has also emerged that the Company, based on what is stated in the document "Equipment used by the worker to perform work and tools for recording access and attendance - Methods and limits of use" (attached to the information provided to the complainant as a collaborator and also addressed to the employees of the Company), processes data related to the individual corporate email accounts in violation of data protection regulations.

3.1. Violation of Articles 5, paragraph 1, letter a) and 13 of the Regulation.

First of all, it should be clarified that, beyond the qualification of the relationship between the Company and the complainant, the processing of the personal data of the data subject is attributable to the Company, which acted as the data controller, according to the definition in Article 4, paragraph 1, number 7 of the Regulation ("data controller: the natural or legal person,... who, alone or jointly with others, determines the purposes and means of the processing of personal data").

In light of the processing carried out, which primarily concerned the data contained in the email inbox, it was found that the information provided by the Company is not compliant with data protection regulations, as it is inadequate and incomplete in fully representing the characteristics and methods of the processing carried out, particularly with regard to the retention periods of data related to email and the methods and purposes for which controls are carried out by the Company as the data controller. In particular, from the examination of the documentation on file, it appears that the information released to the complainant provides, in a very general manner, for the retention of personal data solely to allow the fulfillment of all obligations related to or arising from the conclusion of the employment relationship, indicating a retention period of 10 years in accordance with the provisions of Articles 19 and 22 of Presidential Decree 600/1973.

Similarly, in the part of the document entitled "Equipment used by the worker to perform work and tools for recording access and attendance," the data subject is informed of the processing of logs of access to email and management systems, which are retained "for a duration of at least 6 months."

No information is instead provided regarding the backup of the content of the individual email inbox, during the employment relationship, and the retention of the related content after the termination of the relationship with the Company, which, according to the Company's statements, is planned for 3 years (notes of 13/04/2022 and 05/10/2022).

The part of the document containing instructions on the use of work tools also provides for the possibility, for the Company, to access the email inbox of workers, following the termination of the employment relationship or even in the event of absence, solely to ensure the continuity of the work performance.

In this regard, it is necessary to recall the constant orientation of this Authority which, in its provisions, has always stated that to ensure the ordinary conduct and continuity of business activities, it is necessary to prepare document management systems capable of archiving and preserving documents "in ways suitable to guarantee the characteristics of authenticity, integrity, reliability, readability, and retrievability prescribed by the applicable sector regulations."

Such characteristics cannot be found in email systems which, in fact, serve other purposes (see, among others, provision no. 53 of 01/02/2018, web doc no. 8159221 and provision no. 214 of 29/10/2020, web doc 9518890).

In any case, it emerges from the analysis above that the informational documents prepared by the Company do not provide any information regarding the investigations that the Company reserves the right to conduct on

stored content on company devices nor the necessary clarifications regarding any legitimate, specific, and non-generic reasons underlying such controls and their related methods, which must in any case comply with the principles of legality, proportionality, and graduality (see "Guidelines for email and internet," provision of March 1, 2007, no. 13, web document no. 1387522).

In this regard, it is noted that the content of the information must comply with data protection regulations, as it is not sufficient to inform the data subject of the essential characteristics of the processing; it is also necessary that the information provided outlines operations of processing that are lawful in themselves.

Therefore, the unlawfulness of the processing of personal data carried out by the Company through the prepared information notice must be confirmed, as it is inadequate for the reasons stated. Among other things, it is recalled that the obligation to provide information is an expression of the principle of fairness in processing even within the context of collaborative relationships.

The conduct carried out, therefore, occurred in violation of Articles 5, paragraph 1, letter a) (principle of

fairness) and 13 of the Regulation.

3.2. Violation of Article 5, paragraph 1, letters a), c), and e) and Article 88 of the Regulation and Article 114 of the Code.

An additional aspect of unlawfulness that emerged from the investigative activity pertains to the processing of the content of emails that transit through company accounts, carried out by the Company using a software device called Mail Store.

Based on the statements made, it appears that through this device, the Company performs a backup of the content of the email accounts used by employees and collaborators during the employment/collaboration relationship, systematically and automatically retaining the content for a period of three years after the termination of the employment relationship.

The Company stated in its defense documents that the purpose of this processing is to ensure the security of IT systems, pursuant to Article 5, paragraph 1, letter f) of the Regulation.

Firstly, it is noted that the Company, in light of the retention of the content of communications made by employees and collaborators via email for such an extended period (i.e., throughout the duration of the employment relationship and three years after its termination), did not specify the specific reasons for which, taking into account the concrete characteristics of the systems used, it deemed it necessary to establish such a retention period for the security purposes of the aforementioned systems.

At the same time, the Company did not indicate the specific reasons for which it deemed it necessary to retain the access logs to email and the management system used by employees for the extensive retention period of 6 months (in this regard, see also what was specified by the Authority regarding the retention periods of email logs in the Provision of June 6, 2024, "Guidance Document. IT management programs and services for email in the workplace and processing of metadata," web document no. 10026277).

It clearly emerges that the Mail Store software was used for purposes other than ensuring the security of IT systems. In fact, in the case subject to the complaint, the Company analyzed the emails present in the complainant's account, verified their content, and initiated litigation.

The processing operations carried out through the aforementioned software (such as collection, retention, consultation) that allowed for the reconstruction of the activities of the data subject are in contrast with the principles of legality, data minimization, and limitation of retention (Article 5, paragraph 1, letters a), c), and e) of the Regulation).

Indeed, under the regulations on personal data protection, within the context of employment/collaboration relationships, the data controller may lawfully process personal data, as a rule, only if the processing is necessary for the management of the relationship itself or if it is necessary to fulfill specific obligations or tasks imposed by applicable sector regulations (Article 6, paragraph 1, letters a) and c) of the Regulation, with reference to so-called common data), and in any case may only process data that is adequate, relevant, and limited to what is necessary for the purposes for which they are processed and for a period not exceeding that necessary to achieve the purposes for which they are processed.

In this specific case, however, the systematic retention of emails, carried out for a considerable period of time (equal to three years following the termination of the relationship), as well as the systematic retention of access logs to the email and management system used by workers, are not compliant with data protection regulations, as they are not proportionate and necessary to achieve the stated purposes of ensuring the security of the IT network and the continuity of business operations.

From another perspective, it emerges that the processing that the Company carries out as an employer on the data contained in the email accounts (for example, following the retention of emails received and sent during work activities) assigned to its employees is suitable for allowing monitoring of the activities of workers in violation of what is provided for by Article 4 of Law No. 300 of May 20, 1970, a provision referenced by Article 114 of the Code (see among the last...

measures adopted by the Authority, measure no. 255 of 21/07/2022, web doc no. 9809466, measure no. 137 of 15/04/2021, web doc no. 9670738, measure no. 214 of 29/10/2020, web doc no. 9518890, and measure no. 353 of 29/09/2021, web doc no. 9719914).

Based on Article 114 of the Code, in fact, compliance with the provision of Article 4 of the aforementioned Law No. 300/1970 constitutes a condition of lawfulness for the processing of personal data carried out in the workplace, as it is one of the national law provisions "more specific to ensure the protection of rights and freedoms regarding the processing of personal data of employees within employment relationships" identified by Article 88 of the Regulation (see Articles 5, paragraph 1, letter a) and 88 of the Regulation).

Specifically regarding the violations of Article 114 of the Code, it is noted that the software used by the Company (until the declared suspension of its use), due to its characteristics (as described by the party and considering the information provided to the workers), is capable of implementing a control of work activity (on this point, see among others measure no. 303 of 13/07/2016, web doc no. 5408460).

In particular, the Company, through the aforementioned software, has carried out processing that allows for a detailed reconstruction, even after some time, of the employees' activities, both through communications exchanged via email and through the logs of the management system used to carry out work activities.

Moreover, even if, hypothetically, such processing were aimed at achieving one of the purposes strictly indicated by Article 4, paragraph 1, of Law No. 300/1970, it does not appear that the Company has activated the guarantee procedure provided therein (agreement with the workers' representatives or, in their absence, authorization from the Labor Inspectorate).

Lastly, it is noted that regarding access to electronic mail, delegated to the forensic engineering firm and carried out according to the Company for the "determined and legitimate purpose of protection in judicial matters" (as indicated in the information), the Authority has clarified that the processing of personal data carried out for the purpose of protecting one's rights in court must refer to ongoing disputes or pre-litigation situations, not to abstract and indeterminate hypotheses of possible defense or protection of rights (see measure no. 53 of 01/02/2018, web doc no. 8159221 and measure no. 255 of 21/07/2022, web doc no. 9809466).

In light of the considerations expressed, the unlawfulness of the conduct that occurred in violation of the principles of lawfulness, minimization, and limitation of retention (Article 5, paragraph 1, letters a), c) and e) of the Regulation) and the sector regulations regarding remote monitoring (Article 88 of the Regulation and Article 114 of the Code) must therefore be confirmed.

4. Conclusions: unlawfulness of the processing.

Corrective measures pursuant to Article 58, paragraph 2, of the Regulation.

For the aforementioned reasons, the Authority believes that the statements made by the data controller during the investigation do not allow for overcoming the observations notified by the Office with the initiation of the procedure concerning Articles 5, paragraph 1, letters a), c) and e), 13 and 88 of the Regulation, Article 114 of the Code, which are therefore unsuitable to allow the archiving of this procedure, nor does any of the cases provided for by Article 11 of the Authority's Regulation No. 1/2019 apply with respect to these profiles.

It is recalled that, pursuant to Article 160-bis of the Code, "The validity, effectiveness, and usability in judicial proceedings of acts, documents, and measures based on the processing of personal data not compliant with legal or regulatory provisions remain governed by the relevant procedural provisions."

Given the corrective powers attributed by Article 58, paragraph 2, of the Regulation, in light of the circumstances of the specific case:

- the prohibition of further processing of the data extracted through the Mail Store software is ordered (Article 58, paragraph 2, letter f) of the Regulation);
- the application of an administrative pecuniary sanction is ordered pursuant to Article 83 of the Regulation, commensurate with the circumstances of the specific case (Article 58, paragraph 2, letter

i), of the Regulation).

5. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i), and 83 of the Regulation; Article 166, paragraph 7, of the Code).

At the conclusion of the procedure, it appears that Selectra S.p.A. has violated Articles 5, paragraph 1, letters a), c) and e), 13 and 88 of the Regulation, Article 114 of the Code.

For the violation of the aforementioned provisions, the application of the administrative pecuniary sanction provided for by Article 83, paragraph 5, letters a) and d) of the Regulation is foreseen through the adoption of an injunction order (Article 18, Law 24.11.1981, No. 689).

It is deemed necessary to apply paragraph 3 of Article 83 of the Regulation, which provides that "If, in relation to the same processing or related processing, a data controller [...] violates, with intent or negligence, various provisions of this regulation, the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation," the total amount of the sanction is calculated so as not to exceed the maximum penalty provided for by the same Article 83, paragraph 5, of the Regulation.

With reference to the elements listed in Article 83,

****Paragraph 2 of the Regulation for the purpose of applying the administrative pecuniary sanction and its quantification, taking into account that the sanction must "in any case [be] effective, proportionate, and dissuasive" (Article 83, paragraph 1 of the Regulation), it is represented that, in this specific case, the following circumstances have been considered:****

a) in relation to the nature, severity, and duration of the violation, the nature of the violation concerning the general principles of processing and the obligation of information has been deemed relevant; in particular, the violations also concerned the sector regulations regarding remote monitoring of a significant number of data subjects, considering that as of 31/12/2023, there are 151 employees employed by the Company;

b) with reference to the intentional or negligent nature of the violation and the degree of responsibility of the data controller, the conduct of the Company and its degree of responsibility have been taken into account, as it did not comply with the regulations regarding data protection concerning multiple provisions;

c) the Company cooperated with the Authority during the proceedings, stating that it had suspended the use of the software in order to comply with the indications that will be provided by the Authority;

d) the absence of specific previous violations against the Company.

It is also considered that the economic conditions of the offender are relevant in this case, taking into account the aforementioned principles of effectiveness, proportionality, and dissuasiveness to which the Authority must adhere in determining the amount of the sanction (Article 83, paragraph 1, of the Regulation), primarily based on the revenues achieved by the company concerning the financial statements for the year 2022.

In light of the above elements and the evaluations made, it is deemed appropriate, in this specific case, to apply to Selectra S.p.A. the administrative sanction of payment of an amount equal to €80,000.00 (eighty thousand).

In this context, it is also considered, given the type of violations identified that concerned the general principles of processing, that, pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Authority no. 1/2019, the publication of this provision on the Authority's website should proceed.

It is also deemed that the conditions set forth in Article 17 of Regulation no. 1/2019 are met.

****ALL OF THE ABOVE CONSIDERED, THE AUTHORITY****

finds the unlawfulness of the processing carried out by Selectra S.p.A. represented by its legal

representative, with registered office in Bolzano, Via Antonio Pacinotti no. 11, VAT no. 00123700213 pursuant to Article 143 of the Code, for the violation of Articles 5, paragraph 1, letters a), c) and e), 13, and 88 of the Regulation and Article 114 of the Code;

****ORDERS****

pursuant to Article 58, paragraph 2, letter f) of the Regulation, Selectra S.p.A. is prohibited from further processing the data extracted through the Mail Store software;

****ORDERS****

pursuant to Article 58, paragraph 2, letter i), of the Regulation to pay the sum of €80,000.00 (eighty thousand) as an administrative pecuniary sanction for the violations indicated in this provision;

****ALSO COMMANDS****

the same Company to pay the aforementioned sum of €80,000.00 (eighty thousand), according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts pursuant to Article 27 of Law no. 689/1981.

It is reminded that the offender retains the option to settle the dispute by paying – always according to the methods indicated in the annex – an amount equal to half of the imposed sanction, within the term provided for the submission of the appeal as indicated below (Article 166, paragraph 8, of the Code);

****ORDERS****

the publication of this provision on the Authority's website pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Authority no. 1/2019, and considers that the conditions set forth in Article 17 of Regulation no. 1/2019 are met.

Requests the Company to communicate what initiatives have been undertaken to implement the provisions of this provision and to provide adequately documented feedback pursuant to Article 157 of the Code, within 90 days from the date of notification of this provision; any failure to respond may result in the application of the administrative sanction provided for in Article 83, paragraph 5, letter e) of the Regulation.

Pursuant to Article 78 of the Regulation, as well as Articles 152 of the Code and 10 of Legislative Decree no. 150/2011, an appeal against this provision may be submitted to the ordinary judicial authority, with a petition filed at the ordinary court of the place identified in the same Article 10, within thirty days from the date of communication of the provision itself, or sixty days if the appellant resides abroad.

Rome, July 17, 2024

****THE PRESIDENT****

Stanzione

****THE REPORTER****

Ghiglia

****THE SECRETARY GENERAL****

Mattei